

HiveForce Labs

THREAT ADVISORY

VULNERABILITY REPORT

Samba addressed a series of severe vulnerabilities

Date of Publication

December 19, 2022

Admiralty Code

A1

TA Number

TA2022304

Summary

First Seen: December 19, 2022

Affected Products: Samba

Impact: Elevate privilege and acquire control of impacted systems.

CVEs

CVE	NAME	PATCH
CVE-2022-38023	Weak RC4-HMAC Kerberos encryption in Netlogon RPC	
CVE-2022-37966	Windows Kerberos RC4-HMAC Elevation of Privilege Vulnerability	
CVE-2022-37967	Windows Kerberos Elevation of Privilege Vulnerability	
CVE-2022-45141	Weak RC4-HMAC Kerberos encryption in Heimdal-enabled Samba AD DCs	

Vulnerability Details

#1 Samba is a free-source Windows interoperability package that provides file server, printer, and Active Directory services for Linux, Unix, and macOS operating systems. Samba has resolved a set of flaws that, if exploited successfully, might allow an attacker to seize control of compromised systems.

#2 The CVE-2022-38023 vulnerability exists due to the Netlogon RPC security measures being bypassed. A remote attacker can circumvent the Netlogon cryptography function used for packet signing and sealing during Netlogon authentication. Another CVE-2022-37966 exists due to the application failing to correctly enforce security limitations in Windows Kerberos RC4-HMAC. Upon exploitation, a remote attacker can launch a man-in-the-middle (MiTM) attack, bypassing security limitations and escalating privileges.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-38023	Samba: 4.17.0 - 4.17.3, 4.16.0 - 4.16.7, 4.15.0 - 4.15.12	cpe:2.3:a:samba:samba:- :*.*.*.*.*.*.*	CWE-254
CVE-2022-37966	Samba: 4.17.0 - 4.17.3, 4.16.0 - 4.16.7, 4.15.0 - 4.15.12	cpe:2.3:a:samba:samba:- :*.*.*.*.*.*.*	CWE-264
CVE-2022-37967	Samba: 4.17.0 - 4.17.3, 4.16.0 - 4.16.7, 4.15.0 - 4.15.12	cpe:2.3:a:samba:samba:- :*.*.*.*.*.*.*	CWE-264
CVE-2022-45141	Samba: 4.15.0 - 4.15.12	cpe:2.3:a:samba:samba:- :*.*.*.*.*.*.*	CWE-327

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5’s Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the ‘Potential MITRE ATT&CK TTPs’ & ‘Patch Details’ on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence
<u>TA0004</u> Privilege Escalation	<u>TA0008</u> Lateral Movement	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities
<u>T1078</u> Valid Accounts	<u>T1098</u> Account Manipulation	<u>T1203</u> Exploitation for Client Execution	<u>T1190</u> Exploit Public-Facing Application
<u>T1574</u> Hijack Execution Flow	<u>T1210</u> Exploitation of Remote Services	<u>T1059</u> Command and Scripting Interpreter	<u>T1068</u> Exploitation for Privilege Escalation

Patch Links

<https://www.samba.org/samba/history/security.html>

References

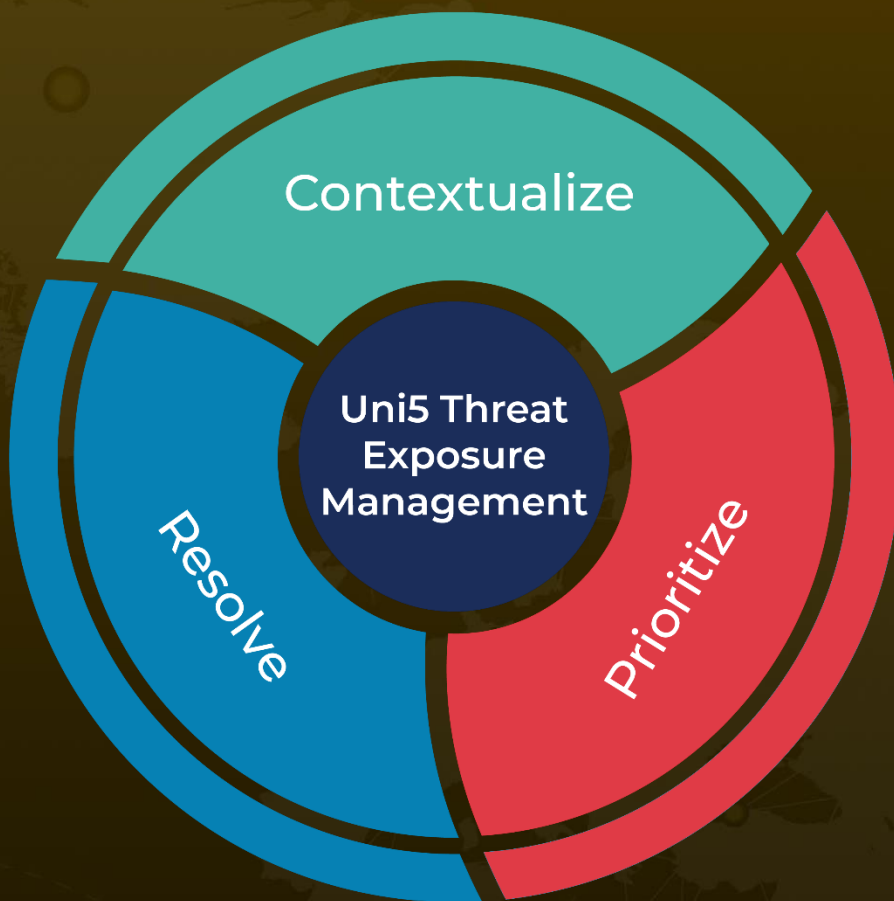
<https://thehackernews.com/2022/12/samba-issues-security-updates-to-patch.html>

<https://www.cisa.gov/uscert/ncas/current-activity/2022/12/16/samba-releases-security-updates>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 19, 2022 • 5:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com